

Aula 2 (Módulo 17) — Credential Dumping

Aula conceitual, focada em evidência e detecção — não um tutorial de exploração. O objetivo é reconhecer quando isso está acontecendo, não executar a técnica.

1. O que o atacante quer

Depois de um acesso inicial (Módulo 02, Aula 5), um objetivo muito comum do atacante é **roubar credenciais** já armazenadas naquele sistema — não para acessar só aquela máquina (já está nela), mas para **se mover lateralmente** para outros sistemas onde essas mesmas credenciais também funcionam (especialmente relevante em ambientes de Active Directory, que veremos com profundidade no Módulo 19).

2. Onde credenciais ficam armazenadas no Windows

LSASS (Local Security Authority Subsystem Service)

É o processo do Windows responsável por autenticação — e, para permitir que o usuário não precise digitar a senha toda vez que acessa outro recurso, o Windows mantém **credenciais na memória desse processo** (hashes, e em certas configurações até senhas em texto claro, dependendo de política e versão do Windows). Isso faz do LSASS um alvo extremamente valioso.

A técnica geral: uma ferramenta acessa a memória do processo `lsass.exe` para extrair essas credenciais — algo que, tecnicamente, usa a mesma capacidade do sistema operacional que um depurador legítimo usaria para inspecionar outro processo (por isso é tão difícil de bloquear completamente sem quebrar funcionalidades legítimas).

Ferramentas conhecidas: a mais citada na indústria (inclusive em material defensivo oficial de vários fabricantes) é o **Mimikatz** — mencionado aqui pelo nome porque reconhecer esse nome/padrão é relevante para detecção (muitas assinaturas de EDR/antivírus procuram justamente por indicadores associados a ele), não como tutorial de uso.

SAM (Security Account Manager)

Um banco de dados local que guarda hashes de senha das contas **locais** daquela máquina (diferente de contas de domínio, que ficam no Active Directory). Fica em `C:\Windows\System32\config\SAM` — normalmente bloqueado para leitura direta enquanto o Windows está rodando, mas acessível através de técnicas específicas (incluindo cópias de sombra do sistema — *Volume Shadow Copy* — abusadas para contornar esse bloqueio).

NTDS.dit

O equivalente ao SAM, mas para um **Domain Controller** inteiro — contém hashes de **todas** as contas de domínio. Extrair isso é um dos objetivos de maior impacto em um ataque contra Active Directory (aprofundamos no Módulo 19).

3. Detecção — o que fica registrado

Sysmon Event ID 10 — Process Access

Este é o Event ID central para esta aula (ainda não formalizado no Módulo 11): registra quando um processo **abre um handle de acesso** para **outro** processo — exatamente o que acontece quando uma ferramenta tenta ler a memória do `lsass.exe`.

```
Event ID 10 (Sysmon)
SourceImage: ferramenta_suspeita.exe
TargetImage: C:\Windows\System32\lsass.exe
GrantedAccess: 0x1010 (ou outros valores associados a leitura de memória)
```

Por que importa: processos legítimos **raramente** precisam de acesso de leitura de memória ao LSASS (o próprio sistema operacional sim, mas ferramentas de usuário comum, não). Uma regra de detecção comum: qualquer processo **não** presente numa lista de exceções conhecida (ferramentas legítimas de segurança/administração) acessando `lsass.exe` com certos níveis de permissão é um forte indicador.

Windows Defender Credential Guard

Uma funcionalidade de **prevenção** (não só detecção) que isola as credenciais em um ambiente virtualizado separado do sistema operacional principal (usando virtualização baseada em hardware) — tornando muito mais difícil, mesmo com acesso administrativo total ao Windows "normal", extrair credenciais da forma tradicional.

Auditoria de acesso a arquivos sensíveis

Acesso ao arquivo SAM ou tentativas de cópia de sombra do sistema (*Volume Shadow Copy*) fora de um contexto de backup legítimo também geram eventos auditáveis — outra fonte de evidência complementar ao Event ID 10.

4. Conectando com o MITRE ATT&CK (Módulo 13)

```
Tática:    Credential Access
Técnica:   T1003 – OS Credential Dumping
Sub-técnicas relevantes:
  T1003.001 → LSASS Memory
  T1003.002 → Security Account Manager (SAM)
  T1003.003 → NTDS (Active Directory)
```

5. Mitigação e hardening

- **Credential Guard** habilitado (seção 3) — a defesa mais forte disponível nativamente no Windows moderno.
- **LSA Protection** (`RunAsPPL`): configura o LSASS para rodar como um **Protected Process**, dificultando (embora não eliminando completamente) o acesso de ferramentas comuns à sua memória.
- **Princípio do menor privilégio** (Módulo 00, Aula 2): limitar quais contas têm privilégio administrativo local reduz drasticamente o número de máquinas onde um atacante consegue sequer **tentar** essa técnica (ela normalmente exige privilégio elevado).
- **Segmentação** (Módulo 03): mesmo que credenciais sejam roubadas em uma máquina, limitar onde elas são **válidas** (contas de domínio restritas, autenticação multifator) reduz o impacto do movimento lateral subsequente.

6. Exercício de reflexão

Usando o método do Módulo 13, Aula 2, monte a cadeia completa (Tática → Técnica → Procedimento → Evidência → Detecção → Resposta) para este cenário: um processo desconhecido, executado a partir de `%TEMP%`, abre um handle de acesso de leitura para `lsass.exe` dois minutos depois de ser criado.

7. Recapitulando

- LSASS guarda credenciais em memória para autenticação sem repetição de senha — alvo primário de credential dumping (T1003.001).
- SAM (local) e NTDS.dit (domínio, Módulo 19) são os bancos de hash correspondentes em disco.
- Sysmon Event ID 10 (Process Access) é a evidência central — acesso de leitura de memória ao LSASS por processo fora da lista de exceções conhecida é um forte indicador.
- Credential Guard, LSA Protection, menor privilégio e segmentação são as camadas de mitigação mais eficazes.

Próxima aula (fecha o Módulo 17)

Técnicas de persistência mais avançadas — indo além das Run keys, serviços e tarefas agendadas já cobertos, com foco em detecção.

Fontes recomendadas

- **Microsoft Learn** — "Protect derived domain credentials with Credential Guard": documentação oficial da defesa mais forte contra credential dumping. <https://learn.microsoft.com/windows/security/identity-protection/credential-guard/>
- **MITRE ATT&CK** — **T1003 (OS Credential Dumping) e sub-técnicas**: referência oficial completa. <https://attack.mitre.org/techniques/T1003/>
- **Microsoft** — "Configuring Additional LSA Protection": documentação oficial de como habilitar LSA Protection (RunAsPPL). <https://learn.microsoft.com/windows-server/security/credentials-protection-and-management/configuring-additional-lsa-protection>